

Contrato de interfaz: Entradas / Inventario ↔ Autenticación (Auth)

Versión: 3.0 (Acuerdo Unificado - Introspección Centralizada)

Equipo consumidor: Entradas / Inventario

Equipo proveedor: Autenticación (Auth)

Basado en: CONTRATO_INTEGRACION_AUTH.md (Épica de Seguridad, HU-B2, HU-B6).

1. Propósito

El equipo de Entradas/Inventario (consumidor) requiere verificar la identidad del cliente que está intentando realizar una compra. Siguiendo el modelo de "Introspección Centralizada de Sesión", Entradas delega completamente la validación del token JWT al microservicio de Autenticación (proveedor). Auth valida la vigencia, firma y estado de revocación, retornando un perfil de usuario unificado que Entradas usará como única fuente de verdad para la identidad durante el proceso de compra.

2. Operación: Validar Sesión (Introspección)

2.1 Descripción

Recibe la cabecera de cookies original, verifica su validez criptográfica y de estado (tokenVersion), y devuelve el perfil normalizado y actualizado del usuario.

2.2 Quién la expone

Equipo Autenticación (Auth).

2.3 Quién la consume

Equipo Entradas / Inventario, de forma obligatoria al recibir una petición de compra (acción crítica) y antes de ejecutar cualquier mutación de datos o reserva de stock.

2.4 Endpoint propuesto

GET /internal/validar-sesion

Nota de seguridad: Este endpoint es estrictamente para la red interna y no está expuesto a Internet.

2.5 Request (lo que se envía)

Campo	Tipo	Obligatorio	Descripción
Cookie (Header)	string	Sí	Cabecera HTTP

			original interceptada del frontend que contiene el atributo "jwt=...".
--	--	--	--

Ejemplo Request Header:

Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...

Regla estricta: Entradas no debe extraer, modificar ni decodificar el JWT por su cuenta.

2.6 Response (lo que se recibe)

Campo	Tipo	Obligatorio	Descripción
valido	boolean	Sí	Indica si la sesión es legítima y está vigente.
usuario.id_usuario	string	Sí	Identificador único del usuario (UUID v4). Única fuente de verdad de identidad.
usuario.nombre_completo	string	Sí	Nombre del usuario (Requerido por Entradas para Check-in y Notificaciones).
usuario.rut	string	Sí	RUT del usuario.
usuario.correo_electronico	string	Sí	Correo electrónico (Requerido por Entradas para Notificaciones).
usuario.rol	string	Sí	Rol vigente del usuario según la base de datos de Auth.

Ejemplo Response (200 OK):

```
{
  "valido": true,
  "usuario": {
    "id_usuario": "3f1e2c1a-4b8d-4a2e-9c3f-7d1e2f9b2d4a",
    "nombre_completo": "Sebastián Fuentes",
    "rut": "21.xxx.xxx-x",
    "correo_electronico": "estudiante@alumnos.uv.cl",
    "rol": "usuario"
  }
}
```

```
}  
}
```

2.7 Códigos de error y Comportamiento

Código Auth	Significado (Auth)	Acción exigida a Entradas
401	Cookie ausente/inválida, JWT expirado/revocado o usuario bloqueado.	Detener proceso, propagar HTTP 401 al Frontend para forzar login.
403	Servicio no autorizado a consultar la red interna.	Bloquear petición, retornar HTTP 403 al Frontend.
500	Error interno en Auth.	Abortar proceso, retornar HTTP 500.
Timeout	Indisponibilidad de red o caída de Auth.	Asumir Fail-Secure, abortar proceso, retornar HTTP 503 al Frontend.

2.8 Tiempo de respuesta esperado (SLA)

< 200 ms (Es una operación crítica y bloqueante al inicio del proceso de compra).

3. Reglas Críticas de Responsabilidad

1. Identidad: Entradas tiene prohibido utilizar un "id_usuario" que provenga del payload o params del Frontend para determinar quién hace la compra. La única identidad válida es el "id_usuario" que devuelve Auth en la propiedad "usuario" del response 200 OK.
2. Autorización: Aunque Auth valida la sesión, Entradas sigue siendo responsable de autorizar las reglas de su propio dominio (ej. verificar que el rol devuelto por Auth tiene permisos para realizar una compra).
3. Privacidad (Logs): Entradas no debe registrar el token JWT completo en texto plano en sus logs. Además, Auth enviará un header "Cache-Control: no-store" que debe respetarse.

4. Acuerdos y Decisiones Tomadas

☒ Se confirma que el endpoint será /internal/validar-sesion.

☒ Se confirma que Entradas no validará firmas ni decodificará tokens localmente; toda validación de sesión se delega mediante introspección.